CHALLENGE SHEET

Shopvault

An e-commerce REST API whose authentication, lockout, and JWT signing weaknesses chain into manager-level access.

DIFFICULTY	TRACK	HOST PORT	LAB ID
HARD	WEB	8080	shopvault

EASY | MEDIUM | HARD | INSANE

VERIFY THE SOLVE

```
• python3 ../scripts/check.py shopvault
```

Brief

ShopVault is an e-commerce REST API. Three accounts are seeded: a shopper, an administrator, and a manager. The manager's private reports hold the flag. No credentials are provided.

Ops note: seed account usernames are not the ones you'd expect.

Setup

Run these from the lab directory:

```
docker compose up -d
```

The API listens on `http://localhost:8080`. All interaction is over HTTP; there is no web UI.

Goal

Escalate from unauthenticated to the manager role and read the manager-only reports endpoint. Verify the solve from the lab directory:

```
python3 ../../../scripts/check.py .
```

See how to play for the usual solve loop.